



# **Architecture, Infrastructure, Security and Data Privacy BrokerVerse OOTB**

Prepared by – **iorta TechNXT**

Version – **1.1**

Date – **04 October 2026**

# TABLE OF CONTENTS

|                                                                                     |           |
|-------------------------------------------------------------------------------------|-----------|
| <b>1. Document Control.....</b>                                                     | <b>4</b>  |
| <b>2. Acronyms.....</b>                                                             | <b>4</b>  |
| <b>3. Introduction.....</b>                                                         | <b>6</b>  |
| <b>3.1 Purpose.....</b>                                                             | <b>6</b>  |
| <b>3.2 Sources and conventions.....</b>                                             | <b>6</b>  |
| <b>3.3 Related documents.....</b>                                                   | <b>7</b>  |
| <b>4. Solution overview and logical architecture.....</b>                           | <b>8</b>  |
| <b>4.1 What BrokerVerse does.....</b>                                               | <b>8</b>  |
| <b>4.2 Architecture at a glance.....</b>                                            | <b>8</b>  |
| <b>4.3 Logical components.....</b>                                                  | <b>9</b>  |
| <b>4.4 Business modules.....</b>                                                    | <b>9</b>  |
| <b>4.5 Integrations.....</b>                                                        | <b>10</b> |
| <b>5. Technology stack and versions.....</b>                                        | <b>13</b> |
| <b>5.1 Runtime and platform.....</b>                                                | <b>13</b> |
| <b>5.2 Backend dependencies.....</b>                                                | <b>13</b> |
| <b>5.3 Front-end dependencies.....</b>                                              | <b>13</b> |
| <b>6. Deployment architecture options.....</b>                                      | <b>15</b> |
| <b>6.1 Common building blocks.....</b>                                              | <b>15</b> |
| <b>6.2 Environment layout.....</b>                                                  | <b>15</b> |
| <b>6.3 Network zones.....</b>                                                       | <b>16</b> |
| <b>6.4 Option A: customer cloud on AWS (Singapore).....</b>                         | <b>16</b> |
| <b>6.5 Option B: Microsoft Azure (Southeast Asia).....</b>                          | <b>18</b> |
| <b>6.6 Option C: local partner or on-premise data centre in the Philippines....</b> | <b>18</b> |
| <b>6.7 Sizing by broker size.....</b>                                               | <b>19</b> |
| <b>6.8 Indicative monthly cost.....</b>                                             | <b>19</b> |
| <b>7. CI/CD and release management.....</b>                                         | <b>21</b> |
| <b>7.1 Workflows in the repository.....</b>                                         | <b>21</b> |
| <b>7.2 Release process.....</b>                                                     | <b>21</b> |
| <b>7.3 Environment configuration and secrets.....</b>                               | <b>22</b> |
| <b>7.4 Database migrations on start.....</b>                                        | <b>23</b> |
| <b>8. High availability, backup and recovery.....</b>                               | <b>24</b> |
| <b>8.1 Resilience properties of the application.....</b>                            | <b>24</b> |
| <b>8.2 Recovery objectives.....</b>                                                 | <b>25</b> |
| <b>8.3 Backup.....</b>                                                              | <b>25</b> |
| <b>8.4 Archival and housekeeping.....</b>                                           | <b>26</b> |
| <b>8.5 Monitoring and alerting.....</b>                                             | <b>27</b> |

|                                                                        |           |
|------------------------------------------------------------------------|-----------|
| <b>9. Security architecture.....</b>                                   | <b>29</b> |
| <b>9.1 Identity and authentication.....</b>                            | <b>29</b> |
| <b>9.2 Authorisation, maker-checker and segregation of duties.....</b> | <b>29</b> |
| <b>9.3 Application security controls (OWASP Top 10, 2021).....</b>     | <b>30</b> |
| <b>9.4 Encryption.....</b>                                             | <b>31</b> |
| <b>9.5 Audit trail and logging.....</b>                                | <b>32</b> |
| <b>9.6 Vulnerability management.....</b>                               | <b>32</b> |
| <b>9.7 Penetration testing approach.....</b>                           | <b>33</b> |
| <b>9.8 Secure development lifecycle.....</b>                           | <b>33</b> |
| <b>10. Data privacy.....</b>                                           | <b>34</b> |
| <b>10.1 Legal framework.....</b>                                       | <b>34</b> |
| <b>10.2 Roles under the DPA.....</b>                                   | <b>34</b> |
| <b>10.3 Personal data held in BrokerVerse.....</b>                     | <b>34</b> |
| <b>10.4 Lawful basis and consent.....</b>                              | <b>35</b> |
| <b>10.5 Data subject rights.....</b>                                   | <b>36</b> |
| <b>10.6 Retention and disposal.....</b>                                | <b>36</b> |
| <b>10.7 Security of personal data.....</b>                             | <b>37</b> |
| <b>10.8 Cross-border transfer.....</b>                                 | <b>37</b> |
| <b>10.9 Breach management.....</b>                                     | <b>37</b> |
| <b>11. Insurance Commission and records.....</b>                       | <b>38</b> |
| <b>12. Compliance checklist.....</b>                                   | <b>39</b> |
| <b>13. Document Sign-Off.....</b>                                      | <b>41</b> |

# 1. Document Control

| Date            | Version | Author & Business Unit Info | Reviewed By & Business Unit Info | Approved By & Business Unit Info | Change History                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------|---------|-----------------------------|----------------------------------|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 04 October 2026 | 1.1.1   | iorta TechNXT               |                                  |                                  | Version 1.1.1: release figures aligned (packages B and G merged on 04 October 2026; backend suite of 104 test files). Version 1.1: new modules (AML/CFT, BIR, operations and accounting, distribution, My Work, go-live workbench), integration framework and its connectors, encryption of personal identifiers at rest and masking by role, runtime theming and e-signatures, release pipeline, IC and NPC compliance registers |

# 2. Acronyms

| Acronym / Symbol | Definition / Meaning                          |
|------------------|-----------------------------------------------|
| OOTB             | Out of the box                                |
| IC               | Insurance Commission                          |
| NPC              | National Privacy Commission                   |
| DPA              | Data Privacy Act of 2012 (Republic Act 10173) |
| IRR              | Implementing Rules and Regulations            |
| DPO              | Data Protection Officer                       |
| PIC              | Personal information controller               |
| PIP              | Personal information processor                |

|          |                                       |
|----------|---------------------------------------|
| SPA      | Single-page application               |
| API      | Application programming interface     |
| RDS      | Amazon Relational Database Service    |
| EFS      | Amazon Elastic File System            |
| WAF      | Web application firewall              |
| CDN      | Content delivery network              |
| RTO      | Recovery time objective               |
| RPO      | Recovery point objective              |
| PITR     | Point-in-time recovery                |
| TOTP     | Time-based one-time password          |
| JWT      | JSON Web Token                        |
| SoD      | Segregation of duties                 |
| BIR      | Bureau of Internal Revenue            |
| DR       | Disaster recovery                     |
| DEV      | Development environment               |
| SIT      | System integration test               |
| PRE-PROD | Pre-production environment            |
| PROD     | Production environment                |
| UAT      | User acceptance testing               |
| AML      | Anti-money laundering                 |
| CFT      | Countering the financing of terrorism |
| AMLC     | Anti-Money Laundering Council         |
| EIS      | Electronic Invoicing System           |
| CTPL     | Compulsory third party liability      |
| COC      | Certificate of cover                  |
| LTO      | Land Transportation Office            |
| PII      | Personally identifiable information   |
| OIDC     | OpenID Connect                        |
| CAB      | Change advisory board                 |

## 3. Introduction

### 3.1 Purpose

This document describes how BrokerVerse OOTB is built, how it can be hosted for a Philippine non-life insurance broker, how it is secured and how it supports the broker's obligations under the Data Privacy Act of 2012. It is written for the broker's management, IT, compliance and data protection officer, and for the support team that takes over the system.

### 3.2 Sources and conventions

The facts in this document come from the source code and configuration of branch `brokerverse-platform` on 04 October 2026 (backend in `backend/`, front end in `brokerverse/`), including the two packages merged into it that day (package B: Insurance Commission and data privacy compliance, with encryption and masking of personal data; package G: sales activities, quote covers and risk fields, supplier BIR Form 2307 and fixed asset disposal), the deployment package in `deploy/` (including `deploy/RELEASE_PIPELINE.md`), the GitHub workflows in `.github/workflows/`, `docker-compose.yml`, the onboarding guides in `docs/onboarding/` and the eleven Solution Architecture documents in `docs/architecture/` (version 1.2, 04 October 2026). Where a statement depends on package B or G it says so.

- Statements without a label describe what the system does today.
- **Recommended** marks a design choice, a size, a threshold or a procedure that iorta TechNXT advises but that is not built into the code or the deployment package. It must be confirmed by the broker and the hosting team.
- **Indicative** marks a cost or size estimate. Indicative figures are planning ranges, not quotations.
- **Gap** marks a point where the current build or pipeline falls short of good practice and needs action before or after go-live.

This document gives the regulatory context in general terms. It is not legal advice; the broker's compliance officer and DPO confirm how each rule applies to the broker.

### 3.3 Related documents

| Document                                                   | Content                                                                                                                                              |
|------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| 01 Solution Component Diagram and Application Architecture | Components, request pipeline, modules, integrations                                                                                                  |
| 02 and 03 Database Design and Inventory                    | Tables, keys, retention classes                                                                                                                      |
| 04 Technology Stack                                        | Versions, licences, lifecycle notes                                                                                                                  |
| 05 Shared Service Components                               | Authentication, settings, audit, numbering, PDF engine                                                                                               |
| 06 to 11                                                   | Capacity, high availability, RTO and RPO, backup, archival, monitoring                                                                               |
| deploy/README.md, deploy/REFERENCE.md                      | Deployment checklist, environment variables, start-up rules                                                                                          |
| docs/onboarding/                                           | Getting started, go-live data set-up and workbench, smoke test and reset, data masking, branding and signatures, UAT scripts, support and escalation |
| deploy/RELEASE_PIPELINE.md                                 | Build once and promote, environments, approvals, migrations policy, rollback, hotfix                                                                 |
| Technical Reference, Data Dictionary                       | Module catalogue, engines, code review; tables, columns and personal data classification                                                             |



## 4. Solution overview and logical architecture

### 4.1 What BrokerVerse does

BrokerVerse OOTB is the operating system of a non-life insurance broker. It covers the full broking cycle: leads and lead assignment, distribution channels and dealer programmes, quotations driven by the Product Configurator, broker slips to several insurers, comparison reports, placement and co-insurance, cover notes, policy issue, fleet schedules, marine open covers, endorsements and computed cancellations, claims with document checklists and motor repairs, renewals, billing with instalment invoices, receipts and post-dated cheques, collections and credit control, remittance to insurers, direct bill, commission, override commission and incentives, reinsurance including facultative placement, accounts payable and fixed assets, bank and insurer statement reconciliation, period-end close, BIR returns, sales invoices and the CAS books, AML/CFT compliance, Insurance Commission and data privacy registers (package B), marketing campaigns, My Work, reports, the report builder and dashboards. Referrers and sub-agents do not sign in; their business is entered by Sales & Marketing.

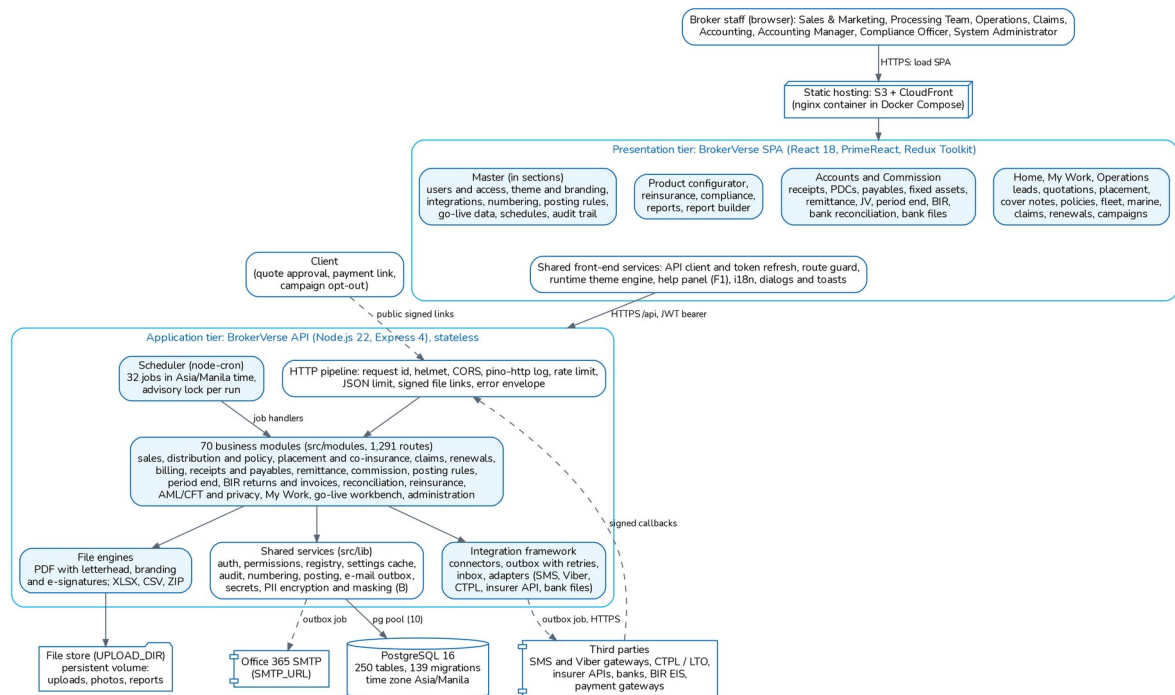
### 4.2 Architecture at a glance

| Aspect            | BrokerVerse OOTB                                                                                                                                                                                                                                                     |
|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Style             | Three-tier web application: SPA, stateless REST API, relational database. The API is a modular monolith.                                                                                                                                                             |
| Presentation tier | React 18 SPA (PrimeReact, Redux Toolkit), served as static files from object storage and a CDN, or from an nginx container                                                                                                                                           |
| Application tier  | Node.js 22 with Express 4. 70 module folders under /api (73 with packages B and G), 1,291 registered routes (1,356), two health endpoints, a built-in scheduler of 32 jobs (35) in Asia/Manila time, an integration framework with an outbox and retries             |
| Data tier         | PostgreSQL 16, database time zone Asia/Manila, 139 migration files (149) applied on start under an advisory lock; 250 tables (260)                                                                                                                                   |
| File store        | Persistent volume at UPLOAD_DIR (documents, ID images, photos, generated reports)                                                                                                                                                                                    |
| Security          | JWT sessions with refresh-token rotation, role and permission checks on every route, maker-checker, authority matrix, SoD rules, access reviews, TOTP two-factor, audit log with source; with package B field encryption of personal identifiers and masking by role |
| Branding          | Runtime theme (colours, logo, sign-in picture) applied to screens, documents, reports and e-mails without a rebuild; e-signatures mapped to documents                                                                                                                |

Route, module and migration counts were taken from the code on 04 October 2026; the figures in brackets include packages B and G. The diagrams come from the architecture set, version 1.2.



## 4.3 Logical components



Logical component view of BrokerVerse OOTB (architecture document 01)

| Layer                 | Components                                                                                                                                                                                                                 |
|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Users                 | Broker staff in a browser; clients through public links (quotation approval, payment checkout)                                                                                                                             |
| Edge                  | DNS, TLS, CDN or reverse proxy, WAF (recommended)                                                                                                                                                                          |
| Presentation          | SPA: Home, My Work, Operations, Accounts, Commission, Reinsurance, Compliance, Reports, Master (in sections), Product Configurator, Dashboards; help panel (F1) with the user manual section of each screen; runtime theme |
| HTTP pipeline         | Request id, security headers (helmet), CORS, access log with redaction, rate limit, JSON size limit, signed file links, one error envelope                                                                                 |
| Business modules      | backend/src/modules: each module owns its routes, services and tables                                                                                                                                                      |
| Shared services       | backend/src/lib: authentication, permissions, settings cache, audit, numbering, e-mail outbox, secrets, personal data encryption and masking (package B), PDF and Excel engines, letterhead and branding                   |
| Integration framework | backend/src/modules/integrations: connectors (test or live), outbox with retries, inbox, adapters for SMS, Viber, CTPL and LTO, insurer APIs and bank files; fake provider for test mode                                   |
| Scheduler             | node-cron jobs with a PostgreSQL advisory lock per run, so each run executes once across instances                                                                                                                         |
| Data                  | PostgreSQL 16 and the file store                                                                                                                                                                                           |

## 4.4 Business modules

| Area                             | Backend modules                                                                                                                                                                              |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sales and operations             | leads, clients, addresses, quotations, packages, premium-charges, placement, comparison-reports, cover-notes, policies, endorsements, cancellations, documents; sales-activities (package G) |
| Distribution and specialty lines | channels, motor-programmes, fleet, marine, campaigns                                                                                                                                         |

| Area                        | Backend modules                                                                                                                         |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| Claims and renewals         | claims, claim-documents, motor-claims, claim-payments, renewals                                                                         |
| Billing and collection      | receipts, collections, credit-control, pdc, payments, payment-gateway                                                                   |
| Insurer accounts            | remittance, insurer-reconciliation, commission, commission-rates, insurer-overrides, incentive, reinsurance                             |
| Accounting and tax          | accounting, posting-rules, journal-vouchers, disbursements, payables, fixed-assets, period-end, bank-reconciliation, bir                |
| Compliance                  | aml, privacy; ic-compliance and data-breaches (package B)                                                                               |
| Integrations                | integrations (framework, messaging, CTPL, insurer connectors, bank payment files)                                                       |
| Configuration               | product-configurator, masters, ops-masters, document-numbering, settings, system-settings, schedules, branding, e-signatures, data-load |
| Administration and security | auth, users, access-control, my-work, notifications, uploads, search, audit, dashboard, reports, report-builder, system                 |

The Technical Reference describes each module (purpose, routes, tables, jobs, posting events, settings).

## 4.5 Integrations

| Integration      | Direction                                                        | How it works                                                                                                                                                                                                                                                                                                                                       |
|------------------|------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| E-mail (SMTP)    | Outbound                                                         | Messages are queued in email_outbox; the email-outbox job sends up to 50 per run every 5 minutes through SMTP_URL (Office 365, port 587, STARTTLS), up to 5 attempts. Off until "Send e-mails" is switched on in Master > Configuration.                                                                                                           |
| Payment gateways | Inbound and outbound                                             | Payment links (PL - numbers) for a quotation, a package quotation or a policy's open premium. Providers: SANDBOX (training and UAT), PayMongo (Checkout Session) and Dragonpay (Payment Switch). Webhooks are signature-checked, logged in payment_events and idempotent; a paid link creates the official receipt and can issue a package policy. |
| Insurers         | Outbound files and e-mail; API through the integration framework | Broker slips, placement orders, remittance statements, commission debit notes as PDF, CSV or XLSX. Insurer API connectors (insurer_rest adapter with a mapping per insurer) send the policy issuance request and receive claim status updates; delivered in test mode until certified with each insurer.                                           |
| SMS and Viber    | Outbound                                                         | Message templates per event                                                                                                                                                                                                                                                                                                                        |

| Integration                                 | Direction                            | How it works                                                                                                                                                                                                                                                                                         |
|---------------------------------------------|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                             |                                      | (renewal notices, payment reminders, claim updates) sent through an SMS gateway connector (Semaphore, Globe Labs or a generic HTTP gateway) or Viber business messages, via the integration outbox; jobs sms-renewal-notices and sms-payment-reminders are delivered off                             |
| CTPL authentication and LTO                 | Outbound and inbound                 | COC numbers allocated from the insurer's series and authenticated with the CTPL provider (ctpl_http), optional LTO feed (lto_http); asynchronous results arrive on the signed inbound endpoint                                                                                                       |
| BIR Electronic Invoicing System             | Outbound                             | Every sales invoice and its cancellation queued as an e-invoice payload (eis_submissions); job eis-outbox delivered off until the broker's EIS accreditation                                                                                                                                         |
| AML screening provider                      | Outbound                             | Optional commercial screening provider through aml_provider_requests (job aml-provider-retry, off); the built-in screening uses the lists loaded in Compliance > Screening Lists                                                                                                                     |
| BI extract                                  | Outbound files                       | Job bi-extract (off) writes one CSV per curated dataset to bi.extract_folder for the broker's BI tool                                                                                                                                                                                                |
| Insurer statements                          | Inbound files                        | CSV or XLSX statements of account read with an insurer statement format (column mapping per insurer) for Accounts > Insurer Reconciliation.                                                                                                                                                          |
| Bank statements                             | Inbound files                        | CSV or XLSX statements read with a bank statement format; BDO, BPI, Metrobank and a generic layout ship as standard.                                                                                                                                                                                 |
| Electronic transfers and bank payment files | Outbound files, inbound status files | Payment vouchers are batched per bank account and written in the bank's bulk credit, InstaPay or PESONet layout (Accounts > Bank Payment Files, layouts in Master > Finance > Bank File Layouts); the bank's status file marks each line paid or rejected and posts the payment. No direct bank API. |
| Reinsurers                                  | Outbound files                       | Bordereaux and reconciliation files as CSV                                                                                                                                                                                                                                                           |
| Uploads and go-live imports                 | Inbound files                        | 10 MB per file, 50 MB decompressed, 20,000 rows; templates in docs/package/05_Delivery/Upload_Templates                                                                                                                                                                                              |
| Document generation                         | Internal                             | One PDF engine (lib/pdf) with the letterhead of the primary                                                                                                                                                                                                                                          |

| Integration               | Direction        | How it works                                                                               |
|---------------------------|------------------|--------------------------------------------------------------------------------------------|
|                           |                  | company in the Company master; XLSX, CSV and ZIP writers. No third-party document library. |
| Client quotation approval | Inbound (public) | Signed link valid for quotations.approval_link_ttl_hours (168 hours)                       |

**Recommended:** Before PayMongo or Dragonpay are switched to live, obtain the merchant accounts and test against the providers' own sandboxes. The automated tests cover the SANDBOX provider and signed test payloads only. Gateway fees are recorded on the link but not journalised.

## 5. Technology stack and versions

Versions are the exact versions resolved in backend/package-lock.json and brokerverse/package-lock.json on 03 October 2026.

### 5.1 Runtime and platform

| Component                 | Version                                                                                                     | Use                                                                     |
|---------------------------|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| Node.js                   | 22 (node:22-alpine; engines >=22)                                                                           | API runtime and build                                                   |
| PostgreSQL                | 16 (postgres:16-alpine in Compose, postgres:16 in CI)                                                       | System of record, extension pgcrypto                                    |
| nginx                     | 1.27-alpine                                                                                                 | Web container (Compose); reverse proxy on the EC2 host                  |
| PM2                       | Latest from npm at deployment                                                                               | Process manager on the EC2 deployment (deploy/ec2/ecosystem.config.cjs) |
| Docker and Docker Compose | Compose file without a version key                                                                          | Single-server, test and trial installations                             |
| GitHub Actions            | checkout, setup-node, upload and download-artifact, configure-aws-credentials v4; appleboy/ssh-action 1.2.0 | CI and deployment                                                       |

### 5.2 Backend dependencies

| Package            | Version         | Purpose                                   |
|--------------------|-----------------|-------------------------------------------|
| express            | 4.22.3          | HTTP server and routing                   |
| pg                 | 8.23.0          | PostgreSQL client, pool of 10 connections |
| zod                | 3.25.76         | Request validation                        |
| pino / pino-http   | 9.14.0 / 10.5.0 | JSON logs with redaction                  |
| helmet             | 8.3.0           | Security headers                          |
| cors               | 2.8.6           | Cross-origin policy                       |
| jsonwebtoken       | 9.0.3           | Access, refresh and link tokens (HS256)   |
| bcryptjs           | 2.4.3           | Password hashing                          |
| multer             | 1.4.5-lts.2     | Multipart uploads in memory with limits   |
| nodemailer         | 10.0.12         | SMTP delivery                             |
| node-cron          | 4.6.0           | Job schedules                             |
| dotenv             | 16.6.1          | .env loading                              |
| vitest / supertest | 2.1.9 / 7.3.0   | Integration tests against PostgreSQL      |
| eslint             | 9.39.5          | Lint                                      |

### 5.3 Front-end dependencies

| Package                           | Version              | Purpose                                |
|-----------------------------------|----------------------|----------------------------------------|
| react, react-dom                  | 18.2.0               | UI library                             |
| react-scripts / @craco/craco      | 5.0.1 / 7.1.0        | Build tool chain                       |
| primereact, primeflex, primeicons | 10.3.1, 3.3.1, 6.0.1 | Components, layout, icons              |
| @reduxjs/toolkit, react-redux     | 2.0.1, 9.0.4         | Application state                      |
| react-router-dom                  | 6.30.6               | Routing                                |
| axios                             | 1.20.0               | HTTP client with token refresh         |
| formik                            | 2.4.5                | Forms                                  |
| i18next, react-i18next            | 25.8.13, 16.5.4      | English (complete), Thai (partial)     |
| chart.js, @fullcalendar           | 4.5.1, 6.1.x         | Charts and calendars                   |
| @fontsource/nunito                | 5.3.0                | Bundled font, no external font service |

The backend has 13 direct runtime dependencies. PDF, XLSX, ZIP, CSV (with formula-injection guarding), TOTP, AES-256-GCM encryption, HMAC link signing and rate limiting are part of the code base. All direct dependencies use permissive licences (MIT, MIT-0, ISC, BSD-2-Clause, Apache-2.0, OFL-1.1).

## 6. Deployment architecture options

### 6.1 Common building blocks

Whatever the hosting option, BrokerVerse needs the same components.

| Component            | Requirement                                                                                                                                                                                                                                                                                                |
|----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Web hosting          | Static files of the SPA ( <code>npm run build</code> , the same build for every environment), with a fallback of every path to <code>index.html</code> ; <code>/env-config.js</code> per environment (API address, environment name) and <code>/api</code> forwarded to the backend                        |
| API runtime          | Container from backend/Dockerfile (runs as user node, port 8000, health check <code>/api/health</code> ) or Node.js 22 under a process manager                                                                                                                                                             |
| Database             | PostgreSQL 16, empty database and a login that may create tables; time zone Asia/Manila; TLS on the connection                                                                                                                                                                                             |
| File store           | Persistent volume at <code>UPLOAD_DIR</code> , shared between instances when there is more than one                                                                                                                                                                                                        |
| Secrets              | <code>JWT_SECRET</code> , <code>DATA_ENCRYPTION_KEY</code> , <code>PII_ENCRYPTION_KEY</code> (package B), <code>ADMIN_PASSWORD</code> , <code>DATABASE_URL</code> , <code>SMTP_URL</code> , payment gateway keys, integration connector credentials (variables named in each connector), in a secret store |
| TLS                  | HTTPS at the CDN, load balancer or reverse proxy                                                                                                                                                                                                                                                           |
| Outbound             | SMTP (port 587) and, when used, the payment gateways, SMS and Viber gateways, the CTPL provider and LTO feed, insurer APIs, the BIR EIS and a screening provider over HTTPS; the addresses are the connector endpoints set by an administrator                                                             |
| Inbound public paths | Quotation approval, payment checkout and gateway webhooks under <code>/api/public/...</code> , signed integration callbacks ( <code>/api/public/integrations/inbound/:connector</code> ), campaign opt-out links, the branding of the sign-in page                                                         |

### 6.2 Environment layout

**Decision (product owner, 04 October 2026):** the environment set follows the broker size. Small and medium brokers have DEV, UAT and PROD: integration is done in DEV and the release is pushed to UAT for testing, then to PROD. Large brokers have DEV, SIT, UAT and PROD, with SIT and UAT separate. PRE-PROD is temporary for every size.

| Environment          | Purpose                                                                                                                       | Data                                                                                                                               | Recommended form                                                                                                        |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| DEV                  | Development and integration by iorta TechNXT; for small and medium brokers also configuration and the system integration test | Sample and synthetic data ( <code>SEED_SAMPLE_DATA=true</code> , <code>backend/scripts/uat-scenario.js</code> ); never client data | Small single-zone environment: one API instance, small managed PostgreSQL without standby                               |
| SIT (large broker)   | System integration test, configuration build and first mock loads                                                             | Synthetic data; client data during mock loads                                                                                      | Single-zone environment, medium size                                                                                    |
| UAT                  | Business acceptance, training, mock loads, performance test                                                                   | Mock-load data from the broker's extracts                                                                                          | Same components as PROD at a smaller size, single zone (small size for small and medium brokers, medium size for large) |
| PRE-PROD (temporary) | Cutover rehearsal before go-live; rehearsal of each major release                                                             | Restored from a PROD backup; masked when used by people without production access                                                  | Same topology and size as PROD; removed after use                                                                       |



| Environment | Purpose                                    | Data                                           | Recommended form                                                                                                                            |
|-------------|--------------------------------------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| PROD        | Live operations                            | Reference data only, then go-live imports      | Two API instances and managed PostgreSQL sized by tier (sizing below); high availability with a standby database required for large brokers |
| DR          | Recovery after a regional or site disaster | Restored from cross-region or off-site backups | Pilot light or warm standby (chapter on resilience); included for the Enterprise size                                                       |

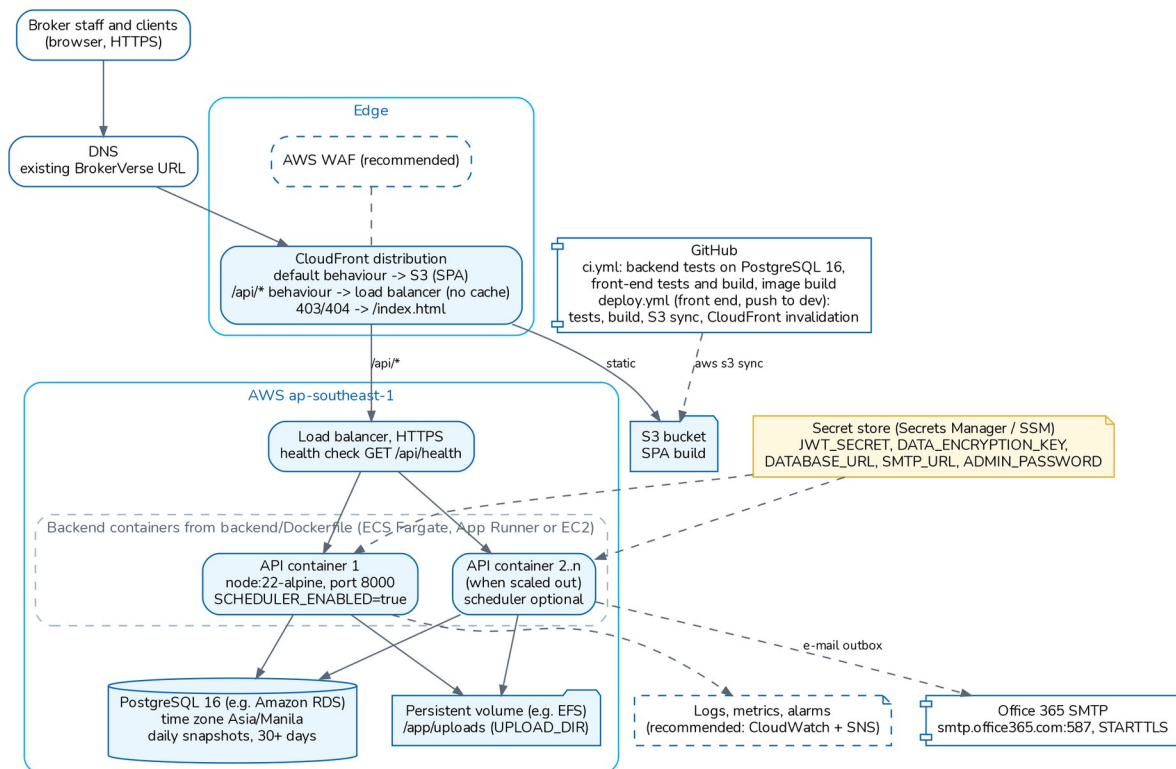
**Recommended:** Never copy production personal data into DEV, SIT or UAT. A PRE-PROD restored from a production backup is masked with the data masking tool before anyone without production access uses it (`npm run mask:data`, docs/onboarding/DATA\_MASKING.md: it refuses on a database marked production, --remark-copy re-marks a restored copy, --register-production records where production lives). Each environment has its own secrets; DATA\_ENCRYPTION\_KEY, JWT\_SECRET and PII\_ENCRYPTION\_KEY differ between environments (a restored copy is masked with production's personal data key, then rotated to its own). The environment marker `system.environment` and the label next to the logo (ENVIRONMENT\_NAME) show which environment a user is in.

## 6.3 Network zones

| Zone                       | Contents                                             | Allowed traffic                                                                                                                              |
|----------------------------|------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Public edge                | DNS, CDN, WAF, public load balancer or reverse proxy | HTTPS 443 from the internet                                                                                                                  |
| Application zone (private) | API instances                                        | From the load balancer only, on the API port; outbound to SMTP, the payment gateways and the enabled integration endpoints only (allow-list) |
| Data zone (private)        | PostgreSQL, file store                               | PostgreSQL 5432 and NFS from the application zone only                                                                                       |
| Management zone            | Bastion or session manager, CI/CD runner access      | Administrator access with multi-factor sign-in, logged                                                                                       |

## 6.4 Option A: customer cloud on AWS (Singapore)

This is the reference deployment of `deploy/README.md` and architecture documents 01 and 07. The region is `ap-southeast-1` (Singapore).



Production deployment on AWS ap-southeast-1 (architecture document 01)

| Component           | AWS service                                                                                                    |
|---------------------|----------------------------------------------------------------------------------------------------------------|
| Web hosting and CDN | Amazon S3 bucket and CloudFront; custom error responses 403 and 404 return /index.html                         |
| API address         | Same-domain option: CloudFront behaviour /api/* to the load balancer, no caching                               |
| API                 | ECS Fargate (recommended), App Runner or EC2, behind an Application Load Balancer with HTTPS (ACM certificate) |
| Database            | Amazon RDS for PostgreSQL 16, Multi-AZ, encrypted with KMS, sslmode=require                                    |
| File store          | Amazon EFS mounted at /app/uploads, encrypted at rest                                                          |
| Backups             | RDS automated backups (35 days, PITR), AWS Backup plans for RDS and EFS, cross-region copies                   |
| Secrets             | AWS Secrets Manager or SSM Parameter Store                                                                     |
| Monitoring          | CloudWatch Logs, metrics, alarms, Synthetics; SNS for notifications                                            |
| WAF                 | AWS WAF on CloudFront with managed rule groups and rate-based rules                                            |
| Image registry      | Amazon ECR, replicated to the recovery region                                                                  |

**Philippine data residency.** The Data Privacy Act does not require personal data to be stored in the Philippines; it makes the broker accountable for personal data transferred abroad (DPA section 21). Hosting in Singapore is therefore a cross-border transfer that the broker documents and covers by contract (chapter on data privacy). AWS has a Local Zone in Manila with a limited set of services (compute and block storage); managed RDS, EFS and the other services above run in the Singapore parent region. A broker that must keep the system of record in the Philippines uses option C, or confirms with AWS which services are available in Manila at the time of the decision.

### 6.4.1 Current demo deployment

The repository also deploys a demo system: the release pipeline (`.github/workflows/deploy.yml`, environment `dev`) publishes the front end to S3 and CloudFront and switches the API on one EC2 host with PM2 (`deploy/ec2/release.sh`). The API runs as one PM2 process (fork mode, restart above 700 MB) on port 8001 behind an nginx site that only forwards `/api/`. This is a single-instance set-up with no redundancy; it is suitable for demonstration and UAT, not as the production form of option A.

## 6.5 Option B: Microsoft Azure (Southeast Asia)

The Azure region Southeast Asia is in Singapore, so the data residency position is the same as for option A. The application needs no code change on Azure: it uses a container, PostgreSQL and a mounted file system.

| Component           | Azure service (recommended mapping)                                                                                     |
|---------------------|-------------------------------------------------------------------------------------------------------------------------|
| Web hosting and CDN | Azure Storage static website with Azure Front Door (CDN and routing of <code>/api/</code> )                             |
| WAF                 | Azure Front Door WAF policy                                                                                             |
| API                 | Azure Container Apps or App Service for Containers, two or more replicas across availability zones                      |
| Database            | Azure Database for PostgreSQL Flexible Server 16, zone-redundant high availability                                      |
| File store          | Azure Files (SMB or NFS share) mounted at <code>/app/uploads</code>                                                     |
| Backups             | Flexible Server automated backups with PITR (up to 35 days), geo-redundant backup storage; Azure Backup for Azure Files |
| Secrets             | Azure Key Vault, referenced by the container app                                                                        |
| Monitoring          | Azure Monitor, Log Analytics, Application Insights availability tests                                                   |
| Registry            | Azure Container Registry                                                                                                |
| Network             | Virtual network with separate subnets for the application and the database (private access)                             |

**Recommended:** The GitHub workflows in the repository target AWS. For Azure, the deployment steps (registry push, container app revision, static website upload, Front Door purge) must be added to the pipeline. Set the database time zone to `Asia/Manila` (server parameter `timezone`) or add the time zone option to `DATABASE_URL`, as done for Railway.

## 6.6 Option C: local partner or on-premise data centre in the Philippines

For a broker that wants the data held in the Philippines, BrokerVerse runs on virtual machines in a local data centre or with a Philippine hosting partner. The Docker Compose file and the EC2 scripts show both ways to run it without cloud managed services.

| Component             | On-premise or partner form                                                                                               |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------|
| Web hosting           | nginx serving the SPA build (the web image of Docker Compose), behind the TLS reverse proxy                              |
| Reverse proxy and WAF | Two nginx or HAProxy nodes with a virtual IP, TLS certificate; WAF appliance or ModSecurity with the OWASP Core Rule Set |
| API                   | Two VMs running the API container (or Node.js 22 with PM2)                                                               |
| Database              | PostgreSQL 16 primary and streaming-replica standby on separate hosts; failover with Patroni or a manual runbook         |
| File store            | NFS share on redundant storage (or a clustered file system)                                                              |

| Component  | On-premise or partner form                                                                                                                                    |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | mounted on both API VMs                                                                                                                                       |
| Backups    | Daily pg_dump -Fc and WAL archiving (pgBackRest or WAL-G) to a backup server; daily archive of the upload share; an off-site copy in a second Philippine site |
| Secrets    | HashiCorp Vault, or an encrypted environment file readable only by the service account, with an escrow copy under dual control                                |
| Monitoring | Prometheus and Grafana or Zabbix, log shipping to a central log server or SIEM, external uptime check                                                         |
| DR         | Second data centre in another Philippine city with replicated backups                                                                                         |

**Recommended:** Ask the partner for evidence of physical security, power and cooling redundancy, and an ISO/IEC 27001 certificate or equivalent. Agree in the contract who patches the operating system, PostgreSQL and the reverse proxy.

## 6.7 Sizing by broker size

The sizes below extend the recommendation of architecture document 06 (200 named users, 80 concurrent, 50,000 policies a year: two API instances of 1 vCPU and 2 GB, database of 2 vCPU and 8 GB Multi-AZ). They apply to PROD and must be confirmed with the UAT performance test.

**Recommended / Indicative:** Assumptions per broker size: small up to 25 named users and about 5,000 policies a year; medium 26 to 100 users and about 20,000 policies; large 101 to 300 users and about 60,000 policies. Uploaded documents average 2 MB per policy. Replace these with the broker's own forecast.

| Item                     | Small (up to 25 users) | Medium (26 to 100)    | Large (101 to 300)     |
|--------------------------|------------------------|-----------------------|------------------------|
| API instances            | 2 x 1 vCPU, 2 GB       | 2 x 1 vCPU, 2 GB      | 3 to 4 x 2 vCPU, 4 GB  |
| Database                 | 2 vCPU, 4 GB, standby  | 2 vCPU, 8 GB, standby | 4 vCPU, 16 GB, standby |
| Database storage         | 50 GB                  | 100 GB                | 250 GB                 |
| File store (year 1)      | 25 GB                  | 60 GB                 | 150 GB                 |
| Backup storage           | 100 GB                 | 250 GB                | 600 GB                 |
| Concurrent users at peak | 10                     | 40                    | 120                    |

## 6.8 Indicative monthly cost

**Indicative:** Hosting prices when iorta TechNXT hosts, from the commercials and pricing workbook (Infrastructure sheet) and the Rate Card: estimates of on-demand list prices at PHP 62.75 to USD 1.00 plus a 20% margin for exchange rate movement and operations, excluding VAT. Reserved capacity or savings plans reduce the cloud cost by roughly 20% to 40%. Obtain a quotation from the provider or partner before ordering.

| Environment (AWS Singapore, PHP a month) | Small     | Medium    | Large      | Enterprise                             |
|------------------------------------------|-----------|-----------|------------|----------------------------------------|
| DEV                                      | 11,000.00 | 11,000.00 | 11,000.00  | 11,000.00                              |
| SIT                                      | Not used  | Not used  | 23,000.00  | 23,000.00                              |
| UAT                                      | 11,000.00 | 11,000.00 | 23,000.00  | 23,000.00                              |
| PROD                                     | 21,000.00 | 47,000.00 | 86,000.00  | 199,000.00 (with cross-region backups) |
| Standing set                             | 43,000.00 | 69,000.00 | 143,000.00 | 256,000.00                             |
| PRE-PROD, per month of use               | 21,000.00 | 47,000.00 | 86,000.00  | 169,000.00                             |

| Standing set, other options (PHP a month) | Small     | Medium    | Large      | Enterprise |
|-------------------------------------------|-----------|-----------|------------|------------|
| B: Azure Southeast Asia                   | 46,000.00 | 73,000.00 | 150,000.00 | 269,000.00 |
| C: Philippine partner                     | 42,000.00 | 67,000.00 | 135,000.00 | 242,000.00 |

| DR option                                                                            | Indicative share of the PROD cost |
|--------------------------------------------------------------------------------------|-----------------------------------|
| DR as pilot light (backups and images in the second region or site, nothing running) | 5% to 10%                         |
| DR as warm standby (small database replica and one API instance running)             | 30% to 50%                        |

The largest cost items are the database with its standby, the load balancer or reverse proxy, the WAF and the log volume. The file store and the backups grow with the number of uploaded documents. PRE-PROD is billed only for the months it exists: the workbook budgets 2 months around go-live and 1 month per major release.

## 7. CI/CD and release management

### 7.1 Workflows in the repository

| Workflow                                               | Trigger                                                        | What it does                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------------------------------|----------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>.github/workflows/ci.yml</code> (CI)             | Every pull request and push; tags <code>v*.*.*</code>          | Backend: <code>npm ci</code> , <code>npm run lint</code> , <code>npm test</code> against a postgres:16 service. Front end: <code>npm ci --legacy-peer-deps</code> , <code>npm run lint</code> , <code>craco test</code> , one environment-neutral build. Dependency audit (production dependencies, high and critical fail). Artefacts <code>web-&lt;sha&gt;</code> and <code>backend-&lt;sha&gt;</code> . Then deploys: <code>brokerverse-platform</code> to dev, <code>vX.Y.Z-rc.N</code> to UAT, <code>vX.Y.Z</code> to Production (GitHub Environments with approvals). |
| <code>.github/workflows/deploy.yml</code> (Deploy)     | Called by CI, or by hand to promote a commit or tag            | Same artefacts in every environment: pre-deploy backup (Pre-Prod, Production), migrations then seeds, API switch on the EC2 host ( <code>deploy/ec2/release.sh</code> ), front end to S3 + CloudFront with <code>/env-config.js</code> , smoke test, automatic rollback. Skipped with a notice when the environment is not configured.                                                                                                                                                                                                                                      |
| <code>.github/workflows/rollback.yml</code> (Rollback) | By hand                                                        | Switches an environment back to an earlier build, without migrations                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <code>brokerverse/.github/workflows/deploy.yml</code>  | Push or pull request, when the front end is its own repository | Front-end lint, tests and environment-neutral build; <code>/env-config.js</code> from repository variables; the publish job runs only for a push to dev                                                                                                                                                                                                                                                                                                                                                                                                                     |

Details, approvals and the GitHub settings: `deploy/RELEASE_PIPELINE.md`. The earlier git-checkout script `deploy/ec2/deploy.sh` (checks out the branch, `npm ci --omit=dev`, creates the database if missing, installs the nginx site after `nginx -t`, starts the API under PM2 and waits for `/api/health`) remains for manual use.

**Gap:** The deploy workflow accepts an IAM role through GitHub OIDC (`AWS_ROLE_ARN`) but falls back to long-lived AWS access keys, and reaches the EC2 host with an SSH key stored per environment. **Recommended:** use the OIDC role in every environment, limited to the bucket and the distribution; for container platforms push the versioned backend image (`backend/Dockerfile`, build arguments `GIT_COMMIT`, `BUILD_TIME`, `GIT_REF`) to a registry and scan it.

**Note:** In `brokerverse/.github/workflows/deploy.yml` the publish job requires the branch `dev` while the trigger is `brokerverse-platform`; as written it tests and builds but does not publish. Align the branch names when the front end is moved to its own repository.

### 7.2 Release process

The release pipeline (`deploy/RELEASE_PIPELINE.md`) builds once and promotes the same artefacts:



1. Merge to brokerverse-platform through a reviewed pull request with the four required checks green; dev deploys automatically.
2. Tag a release candidate vX.Y.Z-rc.N: UAT deploys after the iorta TechNXT delivery lead approves (SIT by hand for a large broker). Run the UAT scripts for the changed areas and obtain business sign-off.
3. For a major release or go-live, deploy the release tag to a PRE-PROD restored from a PROD backup (masked where required), rehearse, run the environment comparison against PROD, then remove PRE-PROD.
4. Tag the release vX.Y.Z: PROD deploys after two reviewers approve (DevOps lead and the broker's release approver or CAB), inside the maintenance window.
5. Every deployment takes a verified pre-deploy backup (always for PRE-PROD and PROD), migrates forward only, switches the API, publishes the front end, runs the smoke test and rolls the application back by itself when the switch or the smoke test fails.
6. rollback.yml switches an environment back to an earlier build; a database restore is a CAB decision.

## 7.3 Environment configuration and secrets

| Variable                                                                                       | Use                                                                                       | Rule enforced at production start                                                   |
|------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| NODE_ENV                                                                                       | production turns on the start-up checks                                                   |                                                                                     |
| DATABASE_URL                                                                                   | PostgreSQL connection, sslmode=require on managed databases                               |                                                                                     |
| JWT_SECRET                                                                                     | Signs sessions, file links and approval tokens                                            | Required, not a placeholder, at least 32 characters                                 |
| DATA_ENCRYPTION_KEY                                                                            | Encrypts TOTP secrets, keys reset-code hashes                                             | Required, at least 32 characters, different from JWT_SECRET                         |
| PII_ENCRYPTION_KEY (package B)                                                                 | Encrypts TIN, government ID and bank account numbers at rest and keys their blind indexes | Required, at least 32 characters, different from JWT_SECRET and DATA_ENCRYPTION_KEY |
| PII_ENCRYPTION_KEY_PREVIOUS (package B)                                                        | Set only during a key rotation (npm run pii:rotate)                                       |                                                                                     |
| APP_ENVIRONMENT                                                                                | Environment of the deployment (dev, sit, uat, preprod, production)                        |                                                                                     |
| ADMIN_PASSWORD                                                                                 | First password of the BrokerVerse administrator                                           | Must meet the password policy                                                       |
| CORS_ORIGINS                                                                                   | Allowed web origins                                                                       | * refused                                                                           |
| PUBLIC_BASE_URL                                                                                | Public API address for links                                                              | localhost refused                                                                   |
| UPLOAD_DIR                                                                                     | File store path                                                                           |                                                                                     |
| SMTP_URL                                                                                       | Mail account                                                                              |                                                                                     |
| SEED_SAMPLE_DATA                                                                               | Demo data on or off (off by default in production)                                        |                                                                                     |
| SCHEDULER_ENABLED                                                                              | Runs scheduled jobs on this instance                                                      |                                                                                     |
| <prefix>_SECRET_KEY,<br><prefix>_WEBHOOK_SECRET,<br><prefix>_MERCHANT_ID,<br><prefix>_PASSWORD | Payment gateway credentials, read only from the environment                               | A gateway cannot go live without them                                               |



| Variable                                                                                                                            | Use                                                                                | Rule enforced at production start                                  |
|-------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| Variables named in each integration connector (credential_env) and in eis.client_id_env, eis.client_secret_env, eis.signing_key_env | Credentials of SMS, Viber, CTPL, LTO, insurer APIs, bank file drop and the BIR EIS | A connector cannot be switched to live while a variable is missing |

If a rule fails, the API logs Refusing to start in production: ... with the reason and exits. Secrets are never stored in the repository; deploy/backend.env.example holds placeholders only.

## 7.4 Database migrations on start

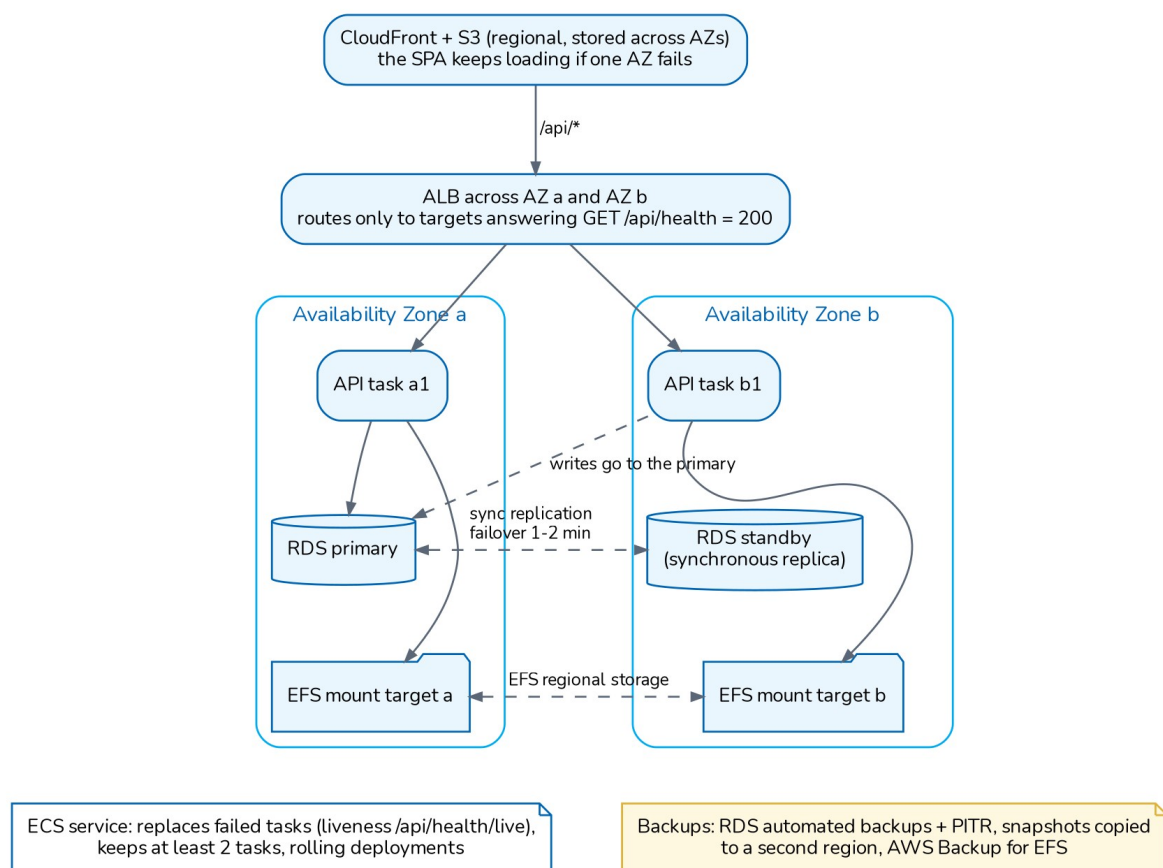
1. The server checks the production configuration.
2. It reports not ready (/api/health answers 503) and takes a PostgreSQL advisory lock. Other instances starting at the same time wait (up to 10 minutes).
3. It applies each pending migration in its own transaction and records it in schema\_migrations, then runs the idempotent seed (roles, permissions, settings, chart of accounts, product templates, jobs, masters, administrator).
4. It starts HTTP and the scheduler and reports ready.

Migrations only add to the schema (project convention), so the previous release normally runs on the newer schema. A failed migration stops the start-up; the release is not rolled back automatically. **Recommended:** test every migration in DEV, SIT (large broker) and UAT, and for a major release in PRE-PROD, and keep a pre-release snapshot.

## 8. High availability, backup and recovery

### 8.1 Resilience properties of the application

| Property                               | Effect                                                                                                                                                                                                  |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Stateless API                          | Any instance serves any request; no sticky sessions                                                                                                                                                     |
| Readiness and liveness                 | /api/health checks the database (2,000 ms timeout) and pending migrations; /api/health/live checks the process only                                                                                     |
| Graceful shutdown                      | On SIGTERM: not ready, scheduler stopped, requests drained, forced exit after 25 s                                                                                                                      |
| Jobs on several instances              | Advisory lock per run; a job runs once even with several schedulers                                                                                                                                     |
| One transaction per business operation | A failure rolls back the whole operation including the document number                                                                                                                                  |
| E-mail outbox                          | SMTP outages delay e-mail without failing transactions                                                                                                                                                  |
| Integration outbox                     | Messages to third parties are queued in the business transaction and sent with retries and exponential backoff; a provider outage never fails or blocks a policy issue; stuck messages are queued again |



*High-availability topology (architecture document 07, recommended)*

**Recommended** production topology: at least two API instances in two availability zones, rolling deployment with 100% minimum healthy, managed PostgreSQL with a synchronous standby, a shared file store across zones, container stop timeout 30 s and load balancer deregistration delay 30 s.

| Single point of failure | Mitigation                                                                                              |
|-------------------------|---------------------------------------------------------------------------------------------------------|
| Database                | Standby with automatic failover; PITR                                                                   |
| File store              | Shared, zone-redundant store with daily backup                                                          |
| Single API instance     | Two or more instances                                                                                   |
| Secrets                 | Versioned secret store and sealed escrow copy of DATA_ENCRYPTION_KEY, PII_ENCRYPTION_KEY and JWT_SECRET |
| Region or site          | Cross-region or off-site copies and a documented recovery                                               |

**Known limitation:** Rate limits are counted per API process, so with N instances the effective limit is N times the setting. **Recommended:** enforce rate limits at the WAF as well.

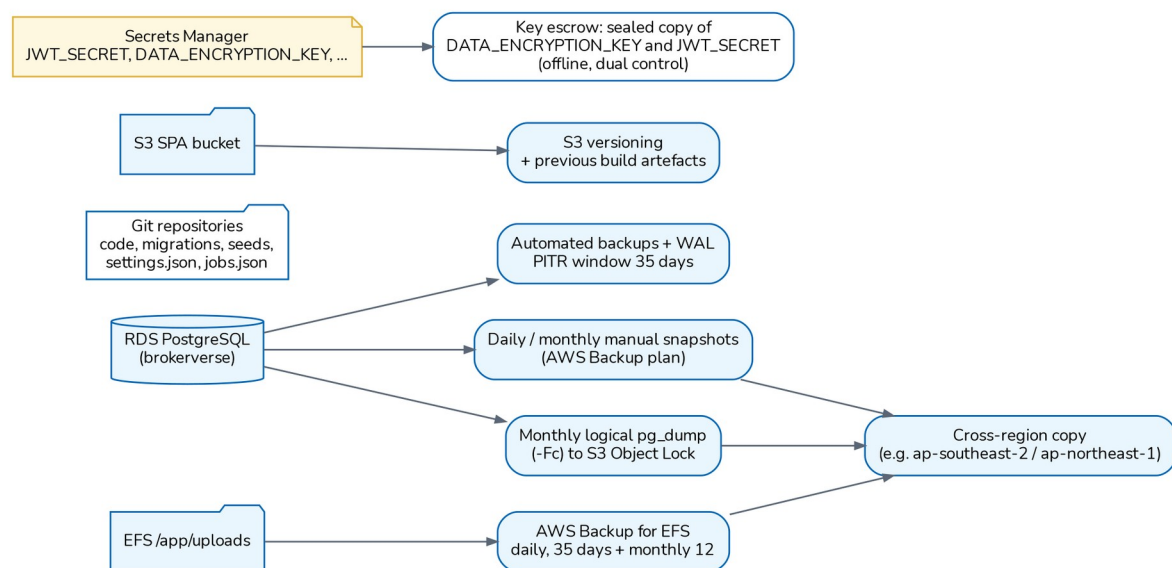
## 8.2 Recovery objectives

**Recommended:** The objectives below are the proposal of architecture document 08. Nothing in the code sets an RTO or RPO; the broker confirms them.

| Scenario                                 | RPO                                         | RTO                                      |
|------------------------------------------|---------------------------------------------|------------------------------------------|
| API instance failure                     | 0                                           | under 5 minutes                          |
| Availability zone failure                | 0                                           | under 15 minutes                         |
| Database instance failure (with standby) | 0                                           | under 15 minutes                         |
| Logical corruption or wrong mass change  | 15 minutes or less (5 achievable with PITR) | 4 hours or less                          |
| Loss of uploaded files                   | 24 hours or less                            | 4 hours or less                          |
| Regional outage                          | 24 hours or less                            | 24 hours or less (warm standby: 8 hours) |
| Front end deleted                        | 0                                           | under 1 hour                             |
| Loss of secrets                          | not applicable                              | under 1 hour                             |

Service tiers: Tier 1 core transactions in PostgreSQL; Tier 2 documents in the file store; Tier 3 derived data (notifications, outbox, generated reports); Tier 4 code and configuration as code, rebuilt from Git.

## 8.3 Backup



*Backup and recovery data flows (architecture document 09, recommended)*

deploy/README.md requires daily automated database snapshots kept at least 30 days, a backup of the upload volume and of DATA\_ENCRYPTION\_KEY (and, with package B, PII\_ENCRYPTION\_KEY, without which the encrypted identifiers in a backup cannot be read), and one restore test before go-live. The release pipeline takes a verified pg\_dump before every deployment to PRE-PROD and PROD (release.sh backup, newest ten kept, copy to BACKUP\_S3\_URI); these are restore points for a release, not the backup plan. Document 09 recommends:

| Backup                                                                                              | Retention (recommended)                                                |
|-----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
| Automated database backups with PITR, window 02:00 to 03:00 Manila time                             | 35 days                                                                |
| Daily and monthly snapshots; monthly copy to a second region                                        | Daily 35 days, monthly 12 months, yearly 10 years for year-end records |
| Snapshot before each release with migrations, before go-live imports and before each year-end close | At least 30 days                                                       |
| Monthly logical dump (pg_dump -Fc) to write-once storage                                            | 12 months                                                              |
| File store daily, weekly copy to the second region                                                  | Daily 35 days, monthly 12 months                                       |
| Front-end bucket versioning                                                                         | 90 days                                                                |
| Container images                                                                                    | Last 10 releases                                                       |

Restore procedures for PITR, snapshots, dumps, files, the front end, secrets and release rollback are in document 09. **Recommended** restore tests: PITR quarterly and before go-live; dump restore twice a year; file restore quarterly; secret escrow check yearly; full DR exercise yearly as a tabletop and every two years in full.

## 8.4 Archival and housekeeping

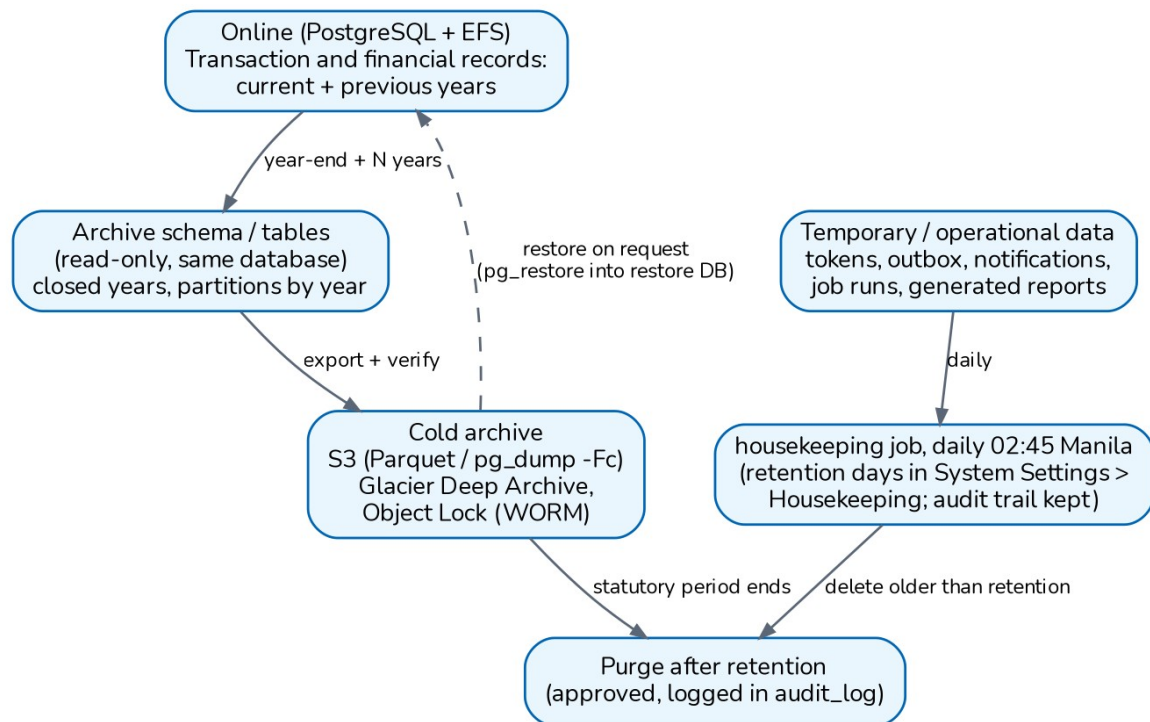
The daily housekeeping job (02:45 Manila time) deletes operational rows past the periods set in System Settings > Housekeeping, in batches of 5,000.

| Data                                       | Default retention                                                        |
|--------------------------------------------|--------------------------------------------------------------------------|
| job_runs                                   | 90 days                                                                  |
| email_outbox sent / failed                 | 180 / 730 days                                                           |
| login_history                              | 365 days                                                                 |
| refresh_tokens expired or revoked          | 30 days                                                                  |
| password_resets                            | 7 days                                                                   |
| Read notifications                         | 180 days                                                                 |
| Completed job_queue items                  | 30 days                                                                  |
| Generated reports (reports.retention_days) | 90 days                                                                  |
| audit_log                                  | Kept (0); never purged below 2,557 days (seven years) if a period is set |

Business and financial records are kept; financial documents are cancelled or reversed, not deleted. The dormant-users job (01:45 daily) deactivates accounts without a sign-in for access.dormant\_days (90 days).

**Gap:** Housekeeping does not yet purge the operational tables added with the new modules: integration\_outbox and integration\_attempts, integration\_inbox, eis\_submissions, aml\_provider\_requests and the rows of loaded go-live workbooks (data\_load\_rows). **Recommended:** add retention rules for them before volumes grow (for example 180 days for sent messages and attempts, 730 days for failed ones, 90

days for workbook rows after the load), keeping AML records for `aml.record_retention_years`.

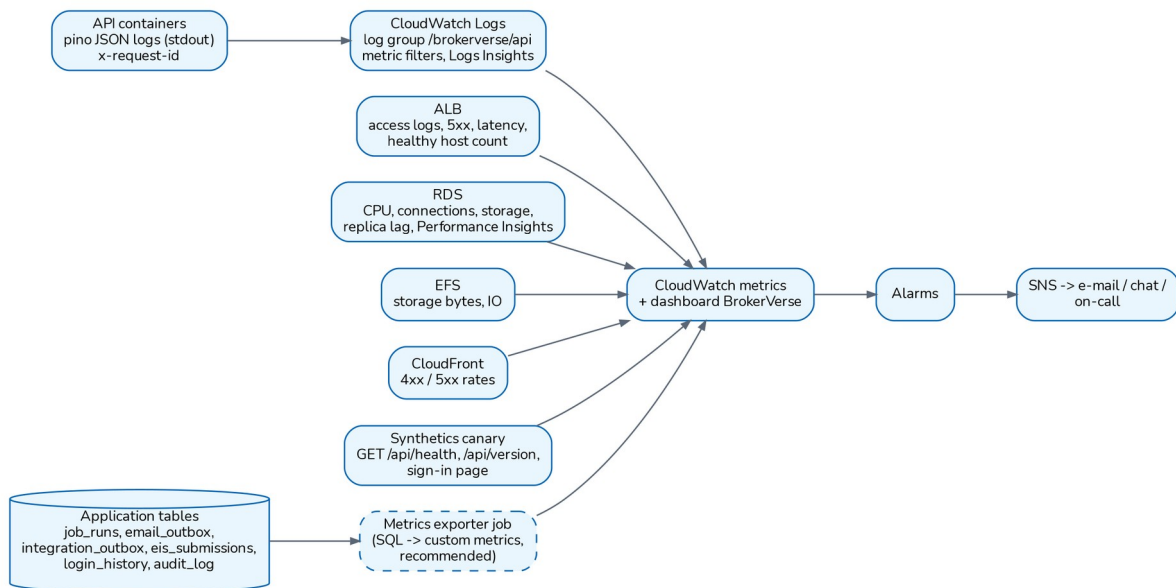


*Data lifecycle: online, archive, purge (architecture document 10, recommended)*

**Recommended:** Document 10 proposes keeping financial and policy records 10 years after the financial year end or policy expiry, unconverted leads and quotations 3 years then anonymised or deleted, and an annual export of closed years to write-once archive storage. The application anonymises the personal data of a client or prospect on request (Master > Data Privacy > Data Subject Requests, Anonymise, with a dry run first); it refuses while the records must still be kept (`privacy.retention_years`, 10 years after the last policy expiry). There is no archive function: the annual export of closed years is a database procedure run by the hosting team under change control.

## 8.5 Monitoring and alerting

The application produces JSON logs on standard output (pino) with a request id on every line and response, redaction of authorization headers, passwords, tokens and signatures, the health and version endpoints, and operational tables (`job_runs`, `email_outbox`, `login_history`, `audit_log`, `generated_reports`). The deployment package contains no monitoring configuration.



*Monitoring and alerting (architecture document 11, recommended)*

| Alarm (recommended)                            | Threshold                                                                                        | Severity |
|------------------------------------------------|--------------------------------------------------------------------------------------------------|----------|
| Synthetic health check                         | 2 consecutive failures, check every 5 minutes                                                    | P1       |
| No healthy API instance                        | 1 minute                                                                                         | P1       |
| HTTP 5xx                                       | over 2% for 5 minutes                                                                            | P1       |
| p95 response time                              | over 2 s for 10 minutes                                                                          | P2       |
| API CPU / memory                               | over 80% for 15 min / over 85% for 10 min                                                        | P2       |
| Database CPU, free storage, connections        | over 80% / under 20% / over 80% of maximum                                                       | P2       |
| Scheduled job failed or not run                | any failure of a daily job; over 26 hours since success                                          | P2       |
| Integration messages failed or stuck           | any message failed, or messages queued over 30 minutes (integration monitor, integration_outbox) | P2       |
| BIR EIS submission rejected or failed          | any (eis_submissions)                                                                            | P2       |
| AML monitoring or breach deadline jobs not run | over 26 hours since success                                                                      | P2       |
| Failed sign-ins                                | over 50 in 5 minutes                                                                             | P2       |
| Refresh-token reuse                            | any                                                                                              | P3       |
| Backup failure or PITR older than 15 minutes   | any                                                                                              | P2       |
| Certificate expiry                             | under 30 days                                                                                    | P3       |

Severity P1 is a 24 x 7 response, P2 the same business day and P3 the next business day, to be aligned with the support agreement in docs/onboarding/SUPPORT\_AND\_ESCALATION.md.



## 9. Security architecture

### 9.1 Identity and authentication

| Control          | Implementation                                                                                                                                                                                                   |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Accounts         | Named users only; no shared or agent sign-in. Users are created in Master > User Management or from a CSV with <code>scripts/provision-users.js</code> ; each must change the initial password at first sign-in. |
| Password storage | bcrypt (cost 10); reset codes stored only as keyed HMAC hashes                                                                                                                                                   |
| Password policy  | Minimum 8 characters, upper and lower case, digit and symbol, history of 5, maximum age 90 days ( <code>security.password_*</code> )                                                                             |
| Lockout          | Account locked after 5 wrong passwords ( <code>limits.max_login_attempts</code> ); 10 attempts per 5 minutes per IP and per username ( <code>security.login_rate_limit</code> )                                  |
| Two-factor       | TOTP (RFC 6238); secrets encrypted with AES-256-GCM; compulsory for the roles in <code>security.require_2fa_roles</code> (empty by default)                                                                      |
| Sessions         | Access token 30 minutes, refresh token 30 days rotated on each use; reuse of a rotated token revokes the token family and is logged                                                                              |
| Revocation       | Password change or reset, deactivation, role or permission change raise the token version and end sessions at once; Master > User Management can end every session of a user                                     |
| Idle sign-out    | 30 minutes ( <code>limits.session_idle_minutes</code> ) with a one-minute warning                                                                                                                                |
| Sign-in history  | Every attempt in <code>login_history</code> with result, reason, IP and user agent                                                                                                                               |

**Recommended:** Before go-live set `security.require_2fa_roles` to at least `system-admin`, `accounting` and `accounting-manager`, as the deployment checklist suggests.

**Known limitation:** Tokens are kept in the browser's local storage (accepted for go-live in `deploy/README.md` section 9). A change to an `httpOnly` refresh cookie is planned. Two-factor enrolment shows the key and a link, not a QR code.

### 9.2 Authorisation, maker-checker and segregation of duties

Permissions are `read:<module>`, `write:<module>` and `approve:<area>` codes (98 with packages B and G), plus `view:pii` for full personal identifiers (package B), checked by the server on every route (`requirePermission`, `requireRole`); the route registry adds the sign-in check to every route that is not explicitly public. The front end also hides menus by role (deny by default).

| Role (seeded)                                          | Main access                                                                                                                                                             |
|--------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System Administrator ( <code>system-admin</code> )     | Every permission; configuration, users and roles                                                                                                                        |
| Sales & Marketing ( <code>sales</code> )               | Leads, clients, quotations, policies, endorsements, renewals, reports                                                                                                   |
| Processing Team ( <code>processing</code> )            | Broker slips and placement, policies, endorsements, renewals, reinsurance, products                                                                                     |
| Operations ( <code>operations</code> )                 | Leads, clients, quotations, policies, endorsements, renewals                                                                                                            |
| Claims ( <code>claims</code> )                         | Claims; read clients and policies                                                                                                                                       |
| Accounting ( <code>accounting</code> )                 | Receipts, collections, disbursements, commission, remittance, incentive, journals, period end, bank reconciliation                                                      |
| Accounting Manager ( <code>accounting-manager</code> ) | Inherits Accounting; approves period close, bank and insurer reconciliations, credit control, payables, posting rule changes                                            |
| Compliance Officer ( <code>compliance-officer</code> ) | AML/CFT: customer risk rating and EDD approval, screening decisions, transaction monitoring, AML cases and AMLC reports; read of clients, policies, claims and payments |



With package B, Sales, Operations and Accounting hold view:pii and see full TIN, ID, mobile, e-mail, bank account and birth date values; Processing and Claims see them masked unless the broker grants it. Operations also keeps the Insurance Commission registers and the complaints register; Claims works complaints.

| Control                  | Implementation                                                                                                                                                                                                                                                                                                                                      |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Administrator protection | Only a System Administrator can grant that role or change an administrator; nobody can change their own roles or status                                                                                                                                                                                                                             |
| Record scope             | Roles listed in security.scoped_roles see only their own records and clients (empty by default)                                                                                                                                                                                                                                                     |
| Maker-checker            | A different user approves journal vouchers, payment vouchers and cheques, commission payouts, remittances and settlements, debit notes, claim settlements, incentive calculations, treaties, petty cash, period closes, reconciliations, quotation and renewal approvals, authority limits and posting rule changes (finance.maker_checker_enabled) |
| Authority matrix         | Approval limits per transaction type and role or user (Master > User Management > Authority Matrix); a new limit applies only after another administrator approves it; default limits in PHP are seeded and replaced by the board-approved signing authority                                                                                        |
| Delegation of authority  | Time-bound delegation of approval authority (leave, travel), revocable (Master > User Management > Delegations)                                                                                                                                                                                                                                     |
| Segregation of duties    | Rules on pairs of roles, checked when roles are assigned (access.sod_enforced). Seeded: placement and payment, placement and payment approval, claims and payment (block); sales and collection, sales and claims (warn)                                                                                                                            |
| Access reviews           | Recertification campaigns over every active user; "revoke" deactivates the account and signs it out (Master > User Management > Access Reviews)                                                                                                                                                                                                     |
| Access reports           | User Access Matrix and Role Permissions, downloadable as XLSX or CSV                                                                                                                                                                                                                                                                                |
| Period control           | Postings refused in closed or locked periods; soft-closed periods only with approve:period-end                                                                                                                                                                                                                                                      |

### 9.3 Application security controls (OWASP Top 10, 2021)

| OWASP risk                    | Controls in BrokerVerse                                                                                                                                                                                         |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A01 Broken access control     | Authentication by default on every route; permission check per route; record scope; maker-checker; signed, expiring file links (30 minutes); masking of personal identifiers by role (package B)                |
| A02 Cryptographic failures    | TLS in transit; bcrypt passwords; AES-256-GCM for TOTP secrets; AES-256-CBC with an HMAC-SHA256 tag for personal identifiers (package B); HMAC-SHA256 for links, reset codes and webhooks; JWT limited to HS256 |
| A03 Injection                 | Parameterised SQL only, dynamic identifiers from white lists; zod validation; CSV formula-injection guarding                                                                                                    |
| A04 Insecure design           | Maker-checker, authority limits, SoD, one transaction per operation, idempotent payment webhooks with amount check                                                                                              |
| A05 Security misconfiguration | Production start refuses unsafe secrets, CORS_ORIGINS=* and localhost URLs; helmet headers; x-powered-by off; sample data off in production                                                                     |
| A06 Vulnerable components     | Lock files with npm ci; npm audit at review (see                                                                                                                                                                |

| OWASP risk                                     | Controls in BrokerVerse                                                                                                                                                                                |
|------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                | vulnerability management)                                                                                                                                                                              |
| A07 Identification and authentication failures | Password policy, lockout, rate limits, TOTP, refresh-token rotation with reuse detection, idle sign-out                                                                                                |
| A08 Software and data integrity failures       | Webhook signatures verified on the raw body; uploads checked by file signature; lock files; reviewed pull requests (recommended)                                                                       |
| A09 Security logging and monitoring failures   | Audit log, sign-in history, request ids, redacted JSON logs; alarms recommended in the monitoring chapter                                                                                              |
| A10 Server-side request forgery                | The API calls only configured provider addresses (SMTP, payment gateways, integration connector endpoints set by an administrator with write:integrations); no address taken from a request is fetched |

Further controls: uploads limited by type (`uploads.allowed_types`, checked by file signature), size (10 MB, 10 files) and decompressed size (50 MB); stored files served with `nosniff` and a sandbox content security policy, and anything other than images and PDF as a download; 5xx responses return a generic message with the request id.

## 9.4 Encryption

| Data                                                    | In transit                                  | At rest                                                                                                                                                                |
|---------------------------------------------------------|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Browser to edge                                         | HTTPS (CDN, load balancer or reverse proxy) |                                                                                                                                                                        |
| Edge to API                                             | HTTPS or private network                    |                                                                                                                                                                        |
| API to database                                         | TLS ( <code>sslmode=require</code> )        | Storage encryption of the managed database (KMS or provider key), recommended on every option                                                                          |
| API to SMTP                                             | STARTTLS on port 587                        |                                                                                                                                                                        |
| File store                                              |                                             | Storage encryption of EFS, Azure Files or the partner's storage (recommended)                                                                                          |
| Backups                                                 |                                             | Encrypted snapshots and write-once storage (recommended)                                                                                                               |
| TOTP secrets                                            |                                             | AES-256-GCM, key derived from <code>DATA_ENCRYPTION_KEY</code>                                                                                                         |
| TIN, government ID and bank account numbers (package B) |                                             | AES-256-CBC with an HMAC-SHA256 tag, keys derived from <code>PII_ENCRYPTION_KEY</code> , encrypted by database triggers on every write; blind indexes for exact search |
| Integration credentials                                 |                                             | Not stored: the connector keeps only the names of the environment variables                                                                                            |
| Password reset codes                                    |                                             | HMAC-SHA256 keyed from <code>DATA_ENCRYPTION_KEY</code>                                                                                                                |
| Sandbox gateway webhook secret                          |                                             | Derived from <code>DATA_ENCRYPTION_KEY</code> when no secret is set                                                                                                    |
| Passwords                                               |                                             | bcrypt hash                                                                                                                                                            |

`DATA_ENCRYPTION_KEY` is not used to encrypt client records or uploaded documents. Losing it makes two-factor secrets unreadable (administrators reset two-factor and

users enrol again); no business data is lost. With package B, TIN, government ID and bank account numbers of clients, prospects, referrers and payees, the identifier keys inside quotation, placement and policy documents and the same values in the audit trail are encrypted with PII\_ENCRYPTION\_KEY; losing that key makes those identifiers unreadable in the database and in every backup. Other client data and uploaded documents rely on storage encryption of the database, file store and backups.

**Key rotation (package B).** Set the new key in PII\_ENCRYPTION\_KEY and the old one in PII\_ENCRYPTION\_KEY\_PREVIOUS, restart, run `npm run pii:rotate` (dry run) and `npm run pii:rotate -- --execute`, then remove the previous key when nothing is left on it. Keep the old key with the backups taken before the rotation.

**Masking by role (package B).** Users without `view:pii` receive personal identifiers partially masked in every screen, export and report file (`privacy.masking_enabled`). With `privacy.pii_reveal_mode` set to `on-request`, even holders see masked values until they switch on "Show full identifiers", and each answer given in full is recorded in the audit trail. Before package B, these values are shown to every user who can open the record.

**Recommended:** Keep DATA\_ENCRYPTION\_KEY, PII\_ENCRYPTION\_KEY and JWT\_SECRET in the secret store with versioning and an escrow copy under dual control. Turn on storage encryption for the database, file store and backups in every option; on premises use encrypted volumes (LUKS or the storage array's encryption).

## 9.5 Audit trail and logging

| Record                                  | Content                                                                                                                                                                                                          |
|-----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| audit_log                               | User, entity, record id, action, before and after JSON, IP, time and source (screen, API or job), written by every mutating handler; kept by default; shown as business events with old and new values per field |
| Field-level and status history          | claim_field_changes, claim_history, period status, bank reconciliation history, remittance approvals                                                                                                             |
| login_history                           | Sign-in attempts, two-factor results, token reuse                                                                                                                                                                |
| payment_events                          | Every gateway notification with signature result                                                                                                                                                                 |
| integration_attempts, integration_inbox | Every call to a third party and every message received, with result                                                                                                                                              |
| Application log                         | JSON on standard output with request id; secrets redacted                                                                                                                                                        |

Master > System Configuration > Audit Trail filters by record type, record, user, action and date and exports to Excel or CSV; the History panel of a record shows its own events. **Recommended** reviews (document 11): monthly access reviews of administrators and new or dormant users; weekly review of changes to settings, posting rules, number series, tax codes and the Company master; monthly review of maker-checker exceptions; weekly review of security events. Ship application logs to central storage kept at least one year.

## 9.6 Vulnerability management

| Item                 | Status                                                                                                                                                                                                |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Backend dependencies | npm audit reported no advisories on 29 September 2026 (document 04); CI runs <code>npm audit --omit=dev --audit-level=high</code> on every pull request and fails on a high or critical advisory in a |

| Item                   | Status                                                                                                                                                                |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                        | production dependency                                                                                                                                                 |
| Front-end dependencies | 71 advisories at the review, almost all build-time dependencies of react-scripts 5.0.1; Create React App is no longer maintained. Move to Vite is the planned remedy. |
| Unused packages        | js-cookie, react-pro-sidebar, web-vitals to be removed                                                                                                                |
| Base images            | node:22-alpine, nginx:1.27-alpine, postgres:16-alpine                                                                                                                 |

**Recommended:** Add an image scan (for example Trivy or the registry's scanner) to the CI audit job; enable GitHub Dependabot alerts and secret scanning; patch critical findings within 14 days and high within 30 days; patch the operating system, PostgreSQL and nginx monthly.

## 9.7 Penetration testing approach

**Recommended:** No penetration test report is part of the repository. Commission an independent test before go-live and yearly, and after major changes.

| Step      | Content                                                                                                                                                  |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Scope     | Web application and API on UAT with production configuration, public paths (approval, payment checkout, webhooks), the hosting perimeter                 |
| Method    | OWASP Web Security Testing Guide and OWASP API Security Top 10; authenticated tests with one user per role                                               |
| Focus     | Access control between roles and scoped users, maker-checker bypass, file link signatures, upload handling, token handling, rate limits, webhook forgery |
| Rules     | Written authorisation by the broker and the hosting provider; test data only; no production personal data                                                |
| Follow-up | Findings rated, fixed and retested; summary kept as evidence for the NPC and auditors                                                                    |

## 9.8 Secure development lifecycle

| Practice            | Current state                                                                                                                                                                                                                                                              |
|---------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Code review         | Pull requests run ci.yml (lint, the backend suite of 104 test files against PostgreSQL 16, front-end lint, tests and build, dependency audit); branch protection requires one approving review and the four checks; the Technical Reference gives the reviewer's checklist |
| Tests               | Backend integration tests with vitest and supertest on a real database; front-end tests with Jest                                                                                                                                                                          |
| Lint rules          | no-console outside scripts, no-unused-vars and eeqeq as errors                                                                                                                                                                                                             |
| Secure defaults     | Production start-up checks; sample data off in production; routes authenticated unless declared public                                                                                                                                                                     |
| API inventory       | npm run export:api writes OpenAPI, Postman and Excel lists of every route and its permission                                                                                                                                                                               |
| Secrets             | Never in the repository; placeholders in deploy/*.env.example                                                                                                                                                                                                              |
| Data classification | Every table classified for the transaction reset and every personal column in the personal data catalogue; tests fail otherwise                                                                                                                                            |

**Recommended:** Image scanning; a short threat review for changes to authentication, payments, integrations and personal data.

## 10. Data privacy

### 10.1 Legal framework

| Instrument                                           | Relevance                                                                                                                                                                            |
|------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data Privacy Act of 2012 (Republic Act 10173)        | Principles of transparency, legitimate purpose and proportionality; lawful criteria for processing; rights of data subjects; security of personal data; accountability for transfers |
| Implementing Rules and Regulations of the DPA (2016) | Detailed duties of controllers and processors, organisational, physical and technical security measures, outsourcing and subcontracting                                              |
| NPC Circular 16-03, Personal Data Breach Management  | Breach response team, notification to the NPC and to affected data subjects within 72 hours of knowledge, breach records and annual report                                           |
| NPC Circular 2022-04                                 | Registration of personal data processing systems and of the DPO with the NPC                                                                                                         |
| Other NPC circulars and advisories                   | Security of personal data, consent, privacy impact assessment and administrative fines; the DPO confirms the current issuances                                                       |

### 10.2 Roles under the DPA

| Party                                  | Role                                                                                 | Main duties                                                                                                                       |
|----------------------------------------|--------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| The broker                             | Personal information controller                                                      | Decides the purposes and means; appoints the DPO; registers with the NPC where required; answers data subjects; notifies breaches |
| iorta TechNXT                          | Personal information processor (when it hosts, supports or accesses production data) | Processes only on the broker's documented instructions; confidentiality; security; assists with rights requests and breaches      |
| Cloud provider or hosting partner      | Sub-processor                                                                        | Infrastructure security under its contract                                                                                        |
| Insurers, reinsurers, payment gateways | Separate controllers or processors for their own processing                          | Covered by the broker's agreements with them                                                                                      |

**Recommended:** Sign a Data Processing Agreement between the broker and iorta TechNXT covering the subject matter and duration, the instructions, confidentiality, security measures (this document), sub-processors (the hosting provider), assistance with rights requests and breaches (notice to the broker without undue delay so the 72-hour deadline can be met), return or deletion of data at the end of the contract, and audit rights.

### 10.3 Personal data held in BrokerVerse

| Data subject                            | Data                                                                | Where                |
|-----------------------------------------|---------------------------------------------------------------------|----------------------|
| Leads and prospects                     | Name, company, e-mail, phone, birth date, gender, address           | Leads                |
| Clients (insured persons and companies) | Name, e-mail, phone, TIN, birth date, gender, address, credit limit | Clients              |
| Insured risks                           | Vehicle plate, chassis and                                          | Quotations, policies |

| Data subject                                         | Data                                                                                                                                   | Where                                                              |
|------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
|                                                      | engine numbers; property locations                                                                                                     |                                                                    |
| KYC                                                  | Government ID type and number (PhilSys ID, UMID, passport, driver's licence and others in <code>policy.kyc_id_types</code> ), ID image | Policies, uploaded documents                                       |
| Claimants and payees                                 | Loss details, description, settlement amounts, payee and bank details, claim documents and photos                                      | claims, claim cash, documents                                      |
| Payments                                             | Payment references, amounts, gateway notifications (no card numbers: card entry happens on the gateway's page)                         | policy_payments, payment_events                                    |
| Referrers and sub-agents                             | Name, bank account, withholding tax data                                                                                               | Referrer master                                                    |
| Staff users                                          | Name, username, e-mail, roles, sign-in history with IP and browser, signature image                                                    | users, login_history, e_signatures                                 |
| Juridical clients' signatories and beneficial owners | Names, IDs, ownership share, board resolutions, due diligence documents                                                                | client_signatories, client_beneficial_owners, client_kyc_documents |
| AML/CFT                                              | Risk rating, screening matches, transaction alerts, case notes, CTR and STR files                                                      | aml_* tables (Compliance Officer only)                             |
| Campaign recipients                                  | Name, e-mail, consent checked, opt-out                                                                                                 | campaign_recipients                                                |
| Complainants and breach records (package B)          | Complainant name and contact, complaint details; breach description and affected data subjects                                         | complaints, personal_data_breaches                                 |

Government-issued identifiers and some claim information (for example injury details in a personal accident claim) are sensitive personal information under the DPA and need the stricter protection the DPA requires. The system holds no structured beneficiary register for policies; named beneficiaries, where captured, sit in policy details or documents.

## 10.4 Lawful basis and consent

| Purpose                                                                               | Usual basis under the DPA (to be confirmed by the DPO)                                                                                                                          |
|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Quotation, placement, policy issue, endorsements, claims, renewals                    | Necessary for a contract with the data subject or steps at their request                                                                                                        |
| Accounting, tax records, BIR forms, IC examination                                    | Compliance with a legal obligation                                                                                                                                              |
| KYC identification                                                                    | Legal obligation and the insurers' underwriting requirements                                                                                                                    |
| Marketing to leads, win-back campaigns, marketing campaigns                           | Consent, or legitimate interest where the DPO concludes it applies; the campaign module sends only to parties with a marketing consent and every e-mail carries an opt-out link |
| AML/CFT customer due diligence, screening, covered and suspicious transaction reports | Compliance with a legal obligation (AMLA and its rules)                                                                                                                         |



Consent is recorded per client or prospect and per purpose (processing, that is the privacy notice acknowledged; marketing; sharing with insurers and reinsurers) on the Data privacy tab of the client and on the prospect view, with the channel, the evidence and the notice version in force (`privacy.notice_version`). A withdrawal is stamped on the consent it ends; records are never deleted. Master > Data Privacy > Consent Register lists every consent across clients and prospects.

**Recommended:** the broker keeps the wording of its privacy notice in its own forms and proposal documents, raises `privacy.notice_version` when the notice changes, and checks the marketing consent before a campaign.

## 10.5 Data subject rights

| Right (DPA section 16 and following) | How it is handled with BrokerVerse                                                                                                                                                                                                                         |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| To be informed                       | Broker's privacy notice; acknowledgement recorded as the processing consent with the notice version                                                                                                                                                        |
| Access                               | Export personal data (JSON or Excel) from the data subject request; client view with its policies; documents in the document viewers                                                                                                                       |
| Rectification                        | Edit the client or lead (Operations screens); every change is in the audit log                                                                                                                                                                             |
| Object and withdraw consent          | Withdraw the consent on the client or prospect; the request is logged with type Objection or Withdraw consent                                                                                                                                              |
| Erasure or blocking                  | Anonymise from the data subject request (dry run first); refused while policy, claim and accounting records must be kept ( <code>privacy.retention_years</code> ). Leads can also be deleted (soft delete). Amounts, numbers and dates stay for the books. |
| Data portability                     | Export personal data in JSON or Excel                                                                                                                                                                                                                      |
| Damages and complaints               | Broker's DPO and complaints procedure                                                                                                                                                                                                                      |

Master > Data Privacy > Data Subject Requests is the register of requests: number from the DSR series, requester, type (Access, Rectification, Erasure or blocking, Objection, Data portability, Withdraw consent), date received and a due date `privacy.request_due_days` (15 calendar days) later, status, assignee, outcome and the exports and anonymisation done for it. The `privacy-requests-due` job (07:00 daily, delivered switched off) notifies the holders of `read:privacy` of open requests past their due date.

**Recommended:** the DPO confirms the response period and switches on the `privacy-requests-due` job at go-live (Master > Schedules).

## 10.6 Retention and disposal

Retention follows the recommendation of architecture document 10 until the compliance officer confirms it: financial and policy records 10 years, audit trail 10 years, unconverted leads and quotations 3 years then anonymised or deleted, security logs 2 years. Housekeeping already removes temporary data automatically (see the archival chapter). Disposal of media follows the hosting provider's certified destruction; on premises, use secure wipe or physical destruction with a certificate.



## 10.7 Security of personal data

The organisational, physical and technical measures required by the DPA and its IRR map to this document as follows.

| Measure                                                                                    | Where addressed                                 |
|--------------------------------------------------------------------------------------------|-------------------------------------------------|
| Organisational: DPO, policies, training, contracts with processors                         | Broker; Data Processing Agreement (recommended) |
| Physical: data centre controls                                                             | Cloud provider or partner certifications        |
| Technical: access control, encryption, audit, monitoring, backup, vulnerability management | Security architecture and resilience chapters   |

## 10.8 Cross-border transfer

When BrokerVerse is hosted in Singapore (options A and B), personal data is stored and processed outside the Philippines. The DPA allows this; the broker remains responsible and must use contractual or other reasonable means to give comparable protection. **Recommended:** record the transfer in the broker's privacy notice and processing records, rely on the provider's data processing terms and certifications, keep encryption keys under the broker's account, and document the decision in a privacy impact assessment. Option C keeps the data in the Philippines.

## 10.9 Breach management

| Step    | Practice with BrokerVerse                                                                                                                                                                                                                                                                                                                |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Detect  | Alarms on failed sign-ins, token reuse, 5xx spikes; audit and sign-in history; WAF logs                                                                                                                                                                                                                                                  |
| Contain | End user sessions (Master > Generals > User Management), deactivate accounts, rotate JWT_SECRET to sign everyone out, block addresses at the WAF                                                                                                                                                                                         |
| Assess  | Use the audit log, login_history and request ids to find which records were affected; with package B record the assessment against the NPC criteria in Compliance > Data Privacy (NPC) > Breach Register                                                                                                                                 |
| Notify  | The broker's DPO notifies the NPC and affected data subjects within 72 hours of knowledge where NPC Circular 16-03 requires it; with package B the Breach Register tracks the 72-hour deadline (privacy.breach_notify_hours) and the privacy-breach-deadlines job reminds the team; iorta TechNXT informs the broker without undue delay |
| Record  | Incident and breach records kept for the annual report to the NPC (package B: annual security incident report from the Breach Register)                                                                                                                                                                                                  |

## 11. Insurance Commission and records

The Amended Insurance Code (Republic Act 10607) and the circulars of the Insurance Commission require licensed brokers to keep complete and accurate books and records of the business they transact, to keep premiums received for insurers apart from their own funds and remit them on time, and to make their records available for examination by the Commission. The IC also expects regulated entities to manage information technology and cyber risk. BrokerVerse supports these expectations as follows; the compliance officer confirms the applicable circulars.

| Expectation                                                | Support in BrokerVerse                                                                                                                                                                          |
|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Complete records of policies placed, premiums, commissions | Policy, billing, receipt, remittance and commission registers with journals from posting rules                                                                                                  |
| Premiums held for insurers and remitted                    | Premium trust bank account in the masters; remittance with multi-level approval; remittance ageing on the insurer's terms                                                                       |
| Records available for examination                          | Reports in XLSX, CSV and PDF; audit trail; retention as recommended above                                                                                                                       |
| Reconciliation with insurers                               | Insurer statement reconciliation with approval and adjustment journals                                                                                                                          |
| Control over changes and approvals                         | Maker-checker, authority matrix, SoD, period locks                                                                                                                                              |
| Licensed persons and payouts (package B)                   | Licence register of the firm, officers and referrers with expiry reminders; payouts to a referrer with a lapsed licence are blocked (compliance.referrer_licence_check); fit and proper records |
| Placement only with authorised insurers (package B)        | Insurer certificate of authority checked at placement and policy issue (compliance.insurer_authority_check)                                                                                     |
| IC annual statement and production report (package B)      | GL accounts mapped to the statement lines; production by line of business and insurer                                                                                                           |
| Complaints handling, RA 11765 (package B)                  | Complaints register with acknowledgement and resolution deadlines, escalation and the regulator reference                                                                                       |
| AML/CFT                                                    | Customer due diligence and onboarding before the first policy, beneficial owners, risk rating and EDD, screening, covered and suspicious transaction monitoring, cases and AMLC report files    |
| IT resilience and security                                 | Backup, recovery objectives, monitoring and security controls in this document                                                                                                                  |

## 12. Compliance checklist

| Control                      | How BrokerVerse meets it                                                                                                                                   | Customer responsibility                                                                                               |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Named user accounts          | Users created per person; initial password changed at first sign-in                                                                                        | Request, approve and remove access through a joiner-mover-leaver process                                              |
| Strong passwords and lockout | Policy of 8 characters with four classes, 5-password history, 90-day age, lockout after 5 failures                                                         | Review the settings before go-live                                                                                    |
| Two-factor authentication    | TOTP built in, compulsory per role                                                                                                                         | Set security.require_2fa_roles; reset two-factor when a phone is lost                                                 |
| Least privilege              | Eight roles with read, write and approve permissions; deny by default; personal identifiers masked without view:pii (package B)                            | Assign roles by job; keep few System Administrators; decide who holds view:pii                                        |
| Segregation of duties        | SoD rules checked on role assignment; maker-checker                                                                                                        | Approve the rule set; act on conflicts in the User Access Matrix                                                      |
| Approval limits              | Authority matrix with approved limits and delegations                                                                                                      | Replace default limits with the board-approved signing authority                                                      |
| Access recertification       | Access Reviews; dormant accounts deactivated after 90 days                                                                                                 | Run a review at least twice a year (recommended)                                                                      |
| Audit trail                  | audit_log with before and after values, kept by default                                                                                                    | Review sensitive changes; set the retention period                                                                    |
| Encryption in transit        | HTTPS; TLS to the database; STARTTLS to SMTP                                                                                                               | Provide certificates; refuse plain HTTP                                                                               |
| Encryption at rest           | TOTP secrets encrypted; passwords hashed; TIN, ID and bank account numbers encrypted (package B)                                                           | Turn on storage encryption for database, files and backups                                                            |
| Secrets management           | Production start refuses weak or missing secrets                                                                                                           | Store secrets in a vault; escrow DATA_ENCRYPTION_KEY and PII_ENCRYPTION_KEY; rotate the personal data key on schedule |
| Backup and restore           | Transactional database; health checks after restore                                                                                                        | Configure backups; test restores quarterly                                                                            |
| High availability            | Stateless API, single job execution, graceful shutdown                                                                                                     | Run two instances and a database standby                                                                              |
| Monitoring                   | Health and version endpoints, JSON logs, operational tables                                                                                                | Set up dashboards, alarms and on-call                                                                                 |
| Vulnerability management     | Lock files; backend audit clean at review                                                                                                                  | Scan in CI; patch OS and middleware; yearly penetration test                                                          |
| Change management            | Pull request CI with required checks; one artefact promoted with approvals per environment; pre-deploy backup; forward-only migrations; automatic rollback | Name the release approvers and CAB; UAT sign-off                                                                      |
| Non-production data          | Data masking tool; environment marker; go-live lock                                                                                                        | Mask every copy of production before people without production access use it                                          |
| DPO and registration         | Not a system function                                                                                                                                      | Appoint the DPO; register with the NPC where required                                                                 |
| Privacy notice and consent   | Consent per purpose with notice version; Consent Register                                                                                                  | Issue the notice; record consent; act on withdrawals                                                                  |
| Data subject rights          | Data Subject Requests register with due dates; export; anonymisation                                                                                       | Log every request; respond within the agreed period                                                                   |
| Retention and disposal       | Housekeeping of temporary data; financial records kept; anonymisation after the retention period                                                           | Approve retention periods; run archival                                                                               |
| Cross-border transfer        | Hosting choice of Singapore or the Philippines                                                                                                             | Document the transfer; sign the provider's data processing terms                                                      |

| Control                   | How BrokerVerse meets it                                                                     | Customer responsibility                                                                                   |
|---------------------------|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|
| Data processing agreement | iorta TechNXT acts on instructions                                                           | Sign the agreement with iorta TechNXT and the hosting partner                                             |
| Breach notification       | Logs and audit data to assess a breach; Breach Register with the 72-hour tracker (package B) | Breach response team; notify NPC and data subjects within 72 hours                                        |
| AML/CFT                   | AML module and the Compliance Officer role                                                   | Appoint the compliance officer; approve the risk factors and thresholds; file CTRs and STRs with the AMLC |
| Complaints (RA 11765)     | Complaints register (package B)                                                              | Set the deadlines and the escalation; report to the IC as required                                        |
| Insurer and IC records    | Registers, reconciliations, reports                                                          | Keep records available for IC examination                                                                 |
| Payment card data         | Card details entered on the gateway's page only                                              | Use gateways that hold the card industry certification                                                    |

### 13. Document Sign-Off

| Serial Number | Description                        | Owner         | Status |
|---------------|------------------------------------|---------------|--------|
| 1             | No open items at the time of issue | iorta TechNXT |        |
|               |                                    |               |        |
|               |                                    |               |        |

| Sign Off Date | Signature | Approved By | Department & Project Role |
|---------------|-----------|-------------|---------------------------|
|               |           |             |                           |
|               |           |             |                           |
|               |           |             |                           |
|               |           |             |                           |



## Insurance technology for the Philippines



**10+**

**COUNTRIES**

Global Presence



**8**

**GLOBAL OFFICES**

Strategically Located



**11+**

**MARKETS SERVED**

Across Continents



**100%**

**COMMITMENT**

To Excellence



**MALAYSIA**



**INDIA**



**PHILIPPINES**



**THAILAND**



**VIETNAM**



**USA**



**ETHIOPIA**



**CAMBODIA**



**HONGKONG**



**SINGAPORE**



Scan More Details